DE RUEDA CONSTRUCTION ERP

Security System Replacement & Legacy Retirement

Formal Upgrade Specification

Purpose: replace the existing security and access-control system completely with the new invitation-only, verified-account, job-position-based authorization model. This is not an optional overlay. Once the replacement is implemented and validated, superseded security paths must be disabled and removed.

1. Replacement scope

The upgrade covers all existing authentication, registration, invitation, account activation, MFA, session management, role/permission checks, API authorization, privileged access, and financial transaction authorization paths. The new model must become the single authoritative security system.

• Retire public/unrestricted signup and replace it with invitation-only registration.

• Retire old account activation rules and require email/identity verification, company-active status, valid employment/authorization, explicit approval, and required MFA.

• Replace legacy role assignments and access checks with approved job-position permissions, site/project scope, and explicit delegation.

• Replace legacy privileged access mechanisms with separately secured, named, audited owner and developer identities.

• Replace legacy financial transaction authorization paths with the CEO master GCash/PayMongo cut-off enforced server-side.

• Retire old session and token mechanisms; invalidate legacy sessions and require users to authenticate under the new model.

2. Migration and cutover strategy

1. Inventory: Identify all old auth providers, signup pages, endpoints, middleware, role checks, session cookies, tokens, service accounts, privileged routes, and payment execution paths.

2. Build replacement: Implement the new controls behind tests and migrate only approved account identities, role assignments, company/site relationships, and necessary settings.

3. Validate: Test positive and negative authorization cases, session invalidation, account status changes, invitation abuse, and payment cut-off enforcement.

4. Cut over: Make the new system the only authority for protected access. Do not leave parallel legacy routes available to browsers, direct API calls, background jobs, or internal services.

5. Retire legacy: Disable and remove obsolete endpoints, public signup routes, old role checks, hidden/backdoor access, stale tokens, mock authorization, and duplicate security logic.

6. Verify production: Deploy the verified build and test the actual live version. Keep a documented rollback plan that does not reactivate the insecure legacy access model.

3. New authoritative access rules

• No public self-registration. Only valid, single-use, expiring invitations bound to an email and company may begin signup.

• Signup creates a Pending Approval account; signup or invitation acceptance never guarantees ERP access.

• Protected access requires verified identity, required MFA, an active company, valid employee/contractor authorization, and explicit approval.

• Company status and individual employment status are independent checks. If status cannot be safely verified, protected access fails closed.

• Each user receives only approved permissions for their job position, company, site, project, records, and delegated responsibilities.

• Regular employees default to read-only access to permitted company information, their own profile, assigned tasks, and their own payslip history.

• CEO, HR, site supervisor, inspector, engineer, architect, project manager, payroll distributor, and other roles receive only their approved capabilities.

• Users cannot self-promote. Sensitive role changes and delegation require authorized approval and an audit record.

• Owner and developer access is separate from ordinary company roles, uses named identities and strong authentication, and has attributable audit logs. No unaudited hidden backdoor or hardcoded credentials are allowed.

4. CEO Vault master transaction cut-off

A CEO-only ON/OFF control must govern new GCash and PayMongo transaction execution across every applicable frontend, API endpoint, batch payout, queue, scheduled task, retry, and manual release path.

• OFF blocks new transaction execution server-side. Hiding buttons or disabling frontend controls is not sufficient.

• ON removes only the global lock; it does not override provider availability, user permissions, account status, site scope, or approval requirements.

• If switch state cannot be safely verified, fail closed and block new transactions.

• Record every switch change with actor, timestamp, old/new state, reason, and result.

• Already-submitted provider transactions may not be reversible; preserve actual status and reconcile them without fabricating success or cancellation.

5. Data and audit-history preservation

Retiring the old security system does not mean deleting valid business records. Preserve employee profiles, employee IDs, attendance, payroll and deductions history, payslips, project/site records, payment evidence, required audit logs, and records subject to retention requirements. Migrate only necessary identity and permission data; validate integrity and access boundaries before cutover.

6. Acceptance and release checklist

Test	Required pass condition
Public signup	No account can register without a valid invitation.
Invitation	Wrong-email, expired, revoked, and reused tokens are rejected.
Pending account	Signup alone grants no protected access.
Company/employment status	Inactive company or ineligible user is denied protected access, including API access.
Role/site isolation	Changing IDs or URLs cannot expose another employee's or site's data.
MFA and sessions	Required MFA is enforced; legacy sessions and tokens no longer authorize access.
Privileged access	Owner/developer access is secured, named, scoped, and audited; no hidden backdoor or hardcoded secret.
Financial cut-off	OFF blocks new GCash/PayMongo execution on every server-side path.
Legacy retirement	Old auth routes, role checks, session mechanisms, and payment authorization paths are disabled/removed.
Data preservation	Historical business records and required audit evidence remain intact and correctly access-controlled.
Production verification	Production build is tested and deployed version verified; npm ci and npm run build succeed.

Completion condition: The upgrade is complete only after the new model is implemented, the legacy mechanisms are retired, security tests pass, historical records are validated, and the deployed production version is verified. Until then, this document is a specification, not evidence of implementation.